

Databehandleravtale (DPA) — Sakspilot

****Versjon:**** 1.0

****Sist oppdatert:**** 28. mai 2026

****Format:**** Bokmål, norsk lov, GDPR-kompatibel (artikkel 28)

Denne mal-en brukes som:

1. ****Vedlegg til Tripletex-partner-søknad**** — viser at Sakspilot har formell databehandleravtale på plass
2. ****Standard DPA**** mellom Sakspilot og pilot-/betalende kunder
3. ****Internt referansedokument**** for sikkerhetsrutiner

****Slik bruker du den:****

- Bytt ut `{KUNDE\_NAVN}`, `{KUNDE\_ORG\_NR}` osv med faktisk kundeinformasjon
- Skriv ut til PDF eller signér digitalt (BankID, Signere.no, Penneo, DocuSign)
- Gi kunden én signert kopi, behold én selv (lagres i `docs/signerte-dpaer/` lokalt — IKKE i Git)
- Oppdater versjonsnummer + dato ved endringer

DATABASEHANDLERAVTALE

****Mellom:****

****Behandlingsansvarlig**** (heretter «Kunden»):

- Navn: `{KUNDE\_NAVN}`
- Organisasjonsnummer: `{KUNDE\_ORG\_NR}`
- Adresse: `{KUNDE\_ADRESSE}`

- Kontaktperson: `{KUNDE\_KONTAKT\_NAVN}`, `{KUNDE\_KONTAKT\_EPOST}`

****Databehandler**** (heretter «Sakspilot»):

- Navn: Helene Åsheim Grønberg (ENK) — eier av Sakspilot
- Organisasjonsnummer: 927889404
- Adresse: Stadionveien 1a 3340 Åmot
- Kontaktperson: Helene Åsheim Grønberg, helene@helene.cloud

Avtalen regulerer Sakspilots behandling av personopplysninger på vegne av Kunden i forbindelse med levering av Sakspilot-tjenesten (sakspilot.no + tilhørende desktop-app).

Avtalen inngås i henhold til personvernforordningen (GDPR) artikkel 28.

1. Definisjoner

«****GDPR****» betyr Europaparlaments- og rådsforordning (EU) 2016/679.

«****Personopplysninger****» har betydningen angitt i GDPR artikkel 4(1).

«****Behandling****» har betydningen angitt i GDPR artikkel 4(2).

«****Den registrerte****» er den fysiske personen personopplysningene gjelder.

«****Underdatabehandler****» er en tredjepart Sakspilot benytter for å levere tjenesten.

2. Bakgrunn og formål

Kunden bruker Sakspilot for å håndtere sin egen virksomhets klient- og prosjektdata, inkludert tidsregistrering, faktureringsgrunnlag, e-postintegrasjon, dokumenthåndtering og AI-assistert tekstgenerering.

For å levere disse tjenestene behandler Sakspilot personopplysninger på vegne av Kunden. Kunden er behandlingsansvarlig; Sakspilot er databehandler.

3. Behandlingens art og formål

Sakspilot behandler personopplysninger kun for følgende formål:

| Formål | Behandlingsaktivitet |

|---|---|

| Klient-CRM | Lagring av klientnavn, kontaktinfo, prosjektnotater |

| Prosjekt/sak-håndtering | Lagring av prosjektittel, beskrivelse, frister, status |

| Tidsregistrering | Lagring av tidsoppføringer, vindustittel, app-navn (kun lokal Sakspilot.exe) |

| E-postintegrasjon | Lesing av e-postemne + avsender for kobling til prosjekt (Microsoft Graph) |

| Faktura-eksport | Overføring av tidsoppføringer + klientdata til regnskapssystem (Tripletex/Fiken) |

| AI-assistent | Sending av prosjekt-tittel + klientnavn (IKKE klient-epost/telefon) til Anthropic Claude for utkast-generering |

| Brukerautentisering | E-post + bcrypt-hashet passord for innlogging |

Sakspilot behandler ikke personopplysninger for andre formål uten skriftlig instruks fra Kunden.

4. Kategorier av personopplysninger

| Kategori | Eksempler |

|---|---|

| ****Identitetsdata (Kunden)**** | Navn, e-post, organisasjonsnummer |

| ****Identitetsdata (klienter)**** | Navn, e-post, telefon, adresse, organisasjonsnummer |

| ****Sakshåndteringsdata**** | Prosjekttittel, beskrivelse, status, frister, milepæler |

| ****Tidsregistreringsdata**** | Vindustittel (f.eks. «Word — kontraktsutkast.docx»), app-navn, varighet, fakturerbar status |

| ****E-postmetadata**** | Emnefelt, avsender, sendt-tidspunkt, kobling til prosjekt |

| ****Autentiseringsdata**** | E-post, bcrypt-hash (ikke klartekstpassord), JWT-token-versjon |

| ****Audit-logg**** | Brukerhandlinger med tidsstempel og IP-adresse (for sikkerhet) |

Sakspilot behandler ikke særlige kategorier av personopplysninger (GDPR art. 9) som hovedregel. Hvis Kundens prosjektnotater inneholder slik informasjon, behandles den med samme sikkerhetstiltak som øvrig data, men Sakspilot anbefaler at sensitive helse-/strafferettsdata håndteres utenfor systemet.

5. Kategorier av registrerte

- Kunden selv (som bruker av Sakspilot)

- Kundens klienter (privatpersoner og foretak)

- Personer Kunden korresponderer med (avsendere av e-poster knyttet til prosjekter)

6. Varighet av behandling

Behandlingen pågår så lenge Kunden har aktiv konto i Sakspilot.

Ved oppsigelse: Kunden kan eksportere alle data via `/innstillinger/sikkerhet` → Last ned alle data (JSON) innen 30 dager. Etter 30 dager slettes data permanent, inkludert backup-roterende kopier innen ytterligere 30 dager.

7. Sakspilots forpliktelser

Sakspilot skal:

1. ****Kun behandle**** personopplysninger på Kundens dokumenterte instruks, herunder ved overføring til tredjeland (denne avtalen utgjør slik instruks).
2. ****Sikre konfidensialitet**** for de som behandler dataene (kun Helene Åsheim Grønberg har tilgang i dag; ev. fremtidige ansatte signerer NDA før tilgang).
3. ****Implementere passende tekniske og organisatoriske tiltak**** for å sikre et passende sikkerhetsnivå (se Vedlegg A).
4. ****Bistå Kunden**** med å oppfylle plikter etter GDPR art. 32–36, herunder:
 - Innsynsforespørsler fra registrerte (`/innstillinger/sikkerhet` → Last ned data `)
 - Retting/sletting av data
 - Dataportabilitet (JSON-eksport)
 - Vurdering av konsekvenser (DPIA) ved spørsmål om systemets datatilgang
5. ****Varsle Kunden uten unødig opphold**** (innen 24 timer) ved personvernbrudd, jf. GDPR art. 33(2). Inkluderer:
 - Beskrivelse av bruddet
 - Antall registrerte berørt
 - Sannsynlige konsekvenser

- Iverksatte tiltak

6. ****Tilbakelevere eller slette**** alle personopplysninger ved avtalens opphør, jf. art. 28(3)(g).

7. ****Stille all nødvendig informasjon**** til rådighet for å vise etterlevelse av art. 28, og tillate revisjoner (se pkt. 11).

8. Underdatabehandlere

Kunden gir Sakspilot ****generell forhåndsgodkjenning**** til å benytte underdatabehandlere, forutsatt at:

- Listen under er oppdatert til enhver tid
- Sakspilot inngår DPA med hver underdatabehandler
- Sakspilot varsler Kunden minst 30 dager før endring/utskifting av underdatabehandler

Aktiv liste pr 28. mai 2026

| Underdatabehandler | Tjeneste | Region | DPA |

|---|---|---|---|

| ****Neon, Inc.**** | Postgres-database (all app-data) | EU (Frankfurt, AWS eu-central-1) | <https://neon.tech/legal/dpa> |

| ****Render, Inc.**** | API-server + logger | EU (Frankfurt) | <https://render.com/legal/dpa> |

| ****Vercel, Inc.**** | Web frontend + statiske assets | Global CDN (data-at-rest i USA) | <https://vercel.com/legal/dpa> |

| ****Microsoft Ireland Operations Ltd.**** | Microsoft Graph (Outlook-integrasjon) — kun aktiv hvis Kunden kobler til | EU (kundens 365-tenant-region) | Microsoft Online Services DPA + SCCs |

| ****Anthropic PBC**** | Claude AI-modell (kun ved bruk av AI-assistent) | USA (eu-west region tilgjengelig via Bedrock-stub, kan aktiveres) | <https://www.anthropic.com/legal/dpa> + SCCs |

| **Tripletex AS** | Regnskaps-API (kun ved aktivert integrasjon) | Norge | Tripletex' standard partner-DPA |

| **Fiken AS** | Regnskaps-API (kun ved Kundens personlig token) | Norge | Fiken-vilkår |

| **Resend (Domain Manager Inc.)** | Transactional e-post (passord-reset, varsler) | EU (Frankfurt) — planlagt aktivering juni 2026 | <https://resend.com/legal/dpa> |

| **Umami Cloud (Umami Software)** | Anonymisert webanalytikk (ingen cookies, ingen PII) | EU | <https://umami.is/legal/dpa> |

Tredjeland-overføringer

Anthropic (USA), Vercel (delvis USA) og Microsoft (delvis USA via 365-tenant) er etablert i USA. For disse benyttes:

- **EUs standardkontrakter (SCC)** modul én/to der relevant

- **Tilleggsbeskyttelse:** PII-minimisering — Sakspilot sender aldri klient-epost eller -telefon til Anthropic

- **Adequacy-vurdering:** USA er ikke ansett som adekvat. SCCs + Data Privacy Framework (DPF) påberopes der underdatabehandler er sertifisert (Microsoft, Vercel)

9. Sikkerhetstiltak

Se **Vedlegg A** for fullstendig liste. Kortversjon:

- All trafikk over TLS 1.2+
- Passord lagres som bcrypt-hash (12 rounds), aldri i klartekst
- JWT med tokenVersion-revokering (30s middleware-cache)
- AES-256-GCM-kryptering av OAuth-tokens og Fiken-API-tokens i databasen
- Multi-tenant isolering via `organizationId` på alle DB-tabeller
- Cascade-sletting når Kunden sletter kontoen

- Audit-logg for sikkerhetshendelser
- Daglige backups (point-in-time recovery 7 dager via Neon)
- Rate-limiting mot brute-force (30 login-forsøk/15 min/IP)

10. Bistand med registreredes rettigheter

Sakspilot bistår Kunden ved henvendelser fra registrerte om:

| Rettighet | Verktøy i Sakspilot |

|---|---|

| Innsyn (art. 15) | `/innstillinger/sikkerhet → Last ned alle data` (JSON) |

| Retting (art. 16) | Kunden retter direkte i Sakspilot-UI |

| Sletting (art. 17) | `/innstillinger/sikkerhet → Slett konto + all data` |

| Dataportabilitet (art. 20) | JSON-eksport (samme som innsyn) |

| Innsigelse (art. 21) | Kontakt helene@helene.cloud — manuell håndtering |

Kunden er ansvarlig for å svare den registrerte. Sakspilot leverer tekniske verktøy.

11. Revisjonsrett

Kunden kan, med rimelig forhåndsvarsel (minst 14 dager) og maks én gang per kalenderår, gjennomføre revisjon av Sakspilots etterlevelse av denne avtalen. Revisjon kan også gjennomføres av tredjepart Kunden velger, forutsatt at tredjeparten er underlagt taushetsplikt.

Sakspilot kan i stedet for fysisk revisjon levere:

- Skriftlig sikkerhetsdokumentasjon (Vedlegg A + audit-logg-utdrag)
- Rapport fra ev. tredjepartsrevisjon (når Sakspilot vokser, planlagt SOC 2 type 1 i 2027)

Kunden bærer egne kostnader ved revisjon. Sakspilots tid faktureres med standardsats (1750 kr/t).

12. Ansvar og erstatning

Begge parter er ansvarlige for skade voldt ved brudd på GDPR, jf. art. 82.

Sakspilots erstatningsansvar overfor Kunden er begrenset til ****12 måneder med abonnementskostnad**** (maks 199 kr × 12 = 2 388 kr pr 2026). Begrensningen gjelder ikke ved grov uaktsomhet eller forsett.

For tidlig-piloter (gratis ut 2026) er ansvarsbegrensningen ****10 000 kr****, men reduseres ikke under det Datatilsynets standardbøter ville krevd.

13. Varighet og opphør

Avtalen trer i kraft ved Kundens registrering på sakspilot.no og varer så lenge Kunden har aktiv konto.

Avtalen kan sies opp av begge parter med ****30 dagers skriftlig varsel**** (e-post til motparten teller).

Ved opphør:

1. Kunden får 30 dagers eksport-vindu
2. Etter 30 dager slettes all kundedata permanent
3. Backup-roterende kopier slettes innen ytterligere 30 dager (total maks 60 dager)
4. Skriftlig sletteattest gis ved forespørsel

14. Lovvalg og vernetting

Avtalen er underlagt norsk rett. Vernetting er Oslo tingrett.

15. Endringer

Endringer krever skriftlig avtale mellom partene. Sakspilot kan oppdatere underdatabehandler-listen i pkt. 8 ved å varsle Kunden 30 dager på forhånd. Hvis Kunden motsetter seg endringen, kan Kunden si opp avtalen.

Signaturer

****For Behandlingsansvarlig (Kunden):****

Sted, dato: _____

Navn: `{KUNDE\_KONTAKT\_NAVN}`

Signatur: _____

****For Databehandler (Sakspilot):****

Sted, dato: _____

Navn: Helene Åsheim Grønberg

Signatur: _____

VEDLEGG A — Tekniske og organisatoriske sikkerhetstiltak

A.1 Konfidensialitet

- Tilgang til produksjonssystemer kun for Helene Åsheim Grønberg (enkelperson-ENK)
- 2FA aktivert på alle administrasjonsskontoer (GitHub, Vercel, Render, Neon)
- Ingen tredjepart har shell-tilgang til produksjonsservere
- Fremtidige ansatte signerer taushetserklæring før tilgang
- Passord lagres som bcrypt-hash med 12 rounds — aldri klartekst
- API-tokens og refresh-tokens krypteres med AES-256-GCM før lagring i DB

A.2 Integritet

- All trafikk over TLS 1.2 eller høyere
- HSTS aktivert (max-age=31536000; includeSubDomains)

- CSP, X-Frame-Options, X-Content-Type-Options satt på alle web-responses
- Input-validering via Zod på alle API-endepunkter
- SQL-injection-beskyttelse via Prisma ORM (kun parametriserte queries)
- CORS strict (`https://sakspilot.no` + `https://www.sakspilot.no` whitelist)
- JWT-signaturer verifiseres på hver request
- JWT-revokering via `User.tokenVersion` (30s middleware-cache, øyeblikkelig revokering ved password-bytte/logout-all)

A.3 Tilgjengelighet

- 99% uptime-mål (Render + Vercel)
- Daglig automatisk backup av database (Neon point-in-time recovery 7 dager)
- Disaster recovery: kan restaureres på ny Neon-instans innen 4 timer
- Helene har lokal kopi av database-skjema og kan gjenoppbygge prod fra git

A.4 Sletting og rotasjon

- Brukere kan slette egen konto via `/innstillinger/sikkerhet`
- Cascade-sletting: User → Organization → alle relaterte tabeller
- Backup-rotasjon: kopier slettes innen 60 dager
- Audit-logg beholdes i 365 dager, deretter automatisk sletting

A.5 Logging og monitorering

- Audit-logg for: innlogging, passord-bytte, GDPR-handlinger, data-eksport, sletting
- Server-logger på Render (oppbevares i 7 dager)
- Sentry for feilmonitorering (anonymisert stack-trace, ingen PII)
- Umami for trafikkanalyse (ingen cookies, ingen IP-lagring utover sesjons-aggregering)

A.6 Sårbarhetsstyring

- npm audit kjøres ved hver build
- GitGuardian skanner commits for secret-eksponering
- Dependabot eller equivalent for sikkerhetsoppdateringer
- Manuelle penetration-test ved første betalende kunde + årlig deretter

A.7 Sub-processor-rotasjon

Endringer i underdatabehandler-listen (pkt. 8 i hovedavtalen) varsles Kunden via:

1. E-post til oppgitt kontaktperson
2. Publikasjon på sakspilot.no/personvern (forrige versjon arkivert)
3. Innloggings-banner i sakspilot.no (krever bekreftelse fra Kunden)

Kunden har 30 dager til å motsette seg endringen før den trer i kraft.

VEDLEGG B — Skjema for personvernbrudd-varsling

(Brukes hvis Sakspilot oppdager et brudd og må varsle Kunden innen 24 timer.)

****Til:**** `{KUNDE\_KONTAKT\_EPOST}`

****Fra:**** helene721@gmail.com

****Emne:**** [VIKTIG] Personvernbrudd-varsel — Sakspilot

****Dato/tid for hendelsen:**** `{TIDSPUNKT}`

****Dato/tid for oppdagelse:**** `{OPPDAGET}`

****Hva har skjedd:****

`{KORT\_BESKRIVELSE}`

****Antall berørte registrerte:****

`{ANTALL}` (anslag — kan oppdateres)

****Kategorier data berørt:****

`{KATEGORIER}` (f.eks. e-post, klientnavn, tidsoppføringer)

****Sannsynlige konsekvenser:****

`{KONSEKVENSER}`

****Tiltak iverksatt:****

`{TILTAK}` (f.eks. tokens revokert, passord-reset tvunget, sårbarhet patchet)

****Tiltak Kunden bør vurdere:****

- Vurder om Kunden må varsle Datatilsynet innen 72 timer (jf. GDPR art. 33)
- Vurder om Kunden må varsle berørte registrerte (jf. art. 34)
- Endre eget passord i Sakspilot

****Kontakt for spørsmål:**** helene721@gmail.com · - 96912907

Siste oppdatering av malen: 28. mai 2026 · Versjon 1.0

